"Internship Task 2: Legal Scope, Asset Inventory & Threat Model"

01. Authorization for Security

Letter of Authorization for Security

Testing Target Environment: Local VirtualBox Vulnerable Lab (IP: 192.168.56.101)

Authorized By: Vivek Kumar (Security Tester)

In-Scope Targets:

- Metasploitable 2 Virtual Machine (IP: 192.168.56.101)
- All ports and services running on this specific virtual IP.

Out-of-Scope Targets (Strictly NO Testing):

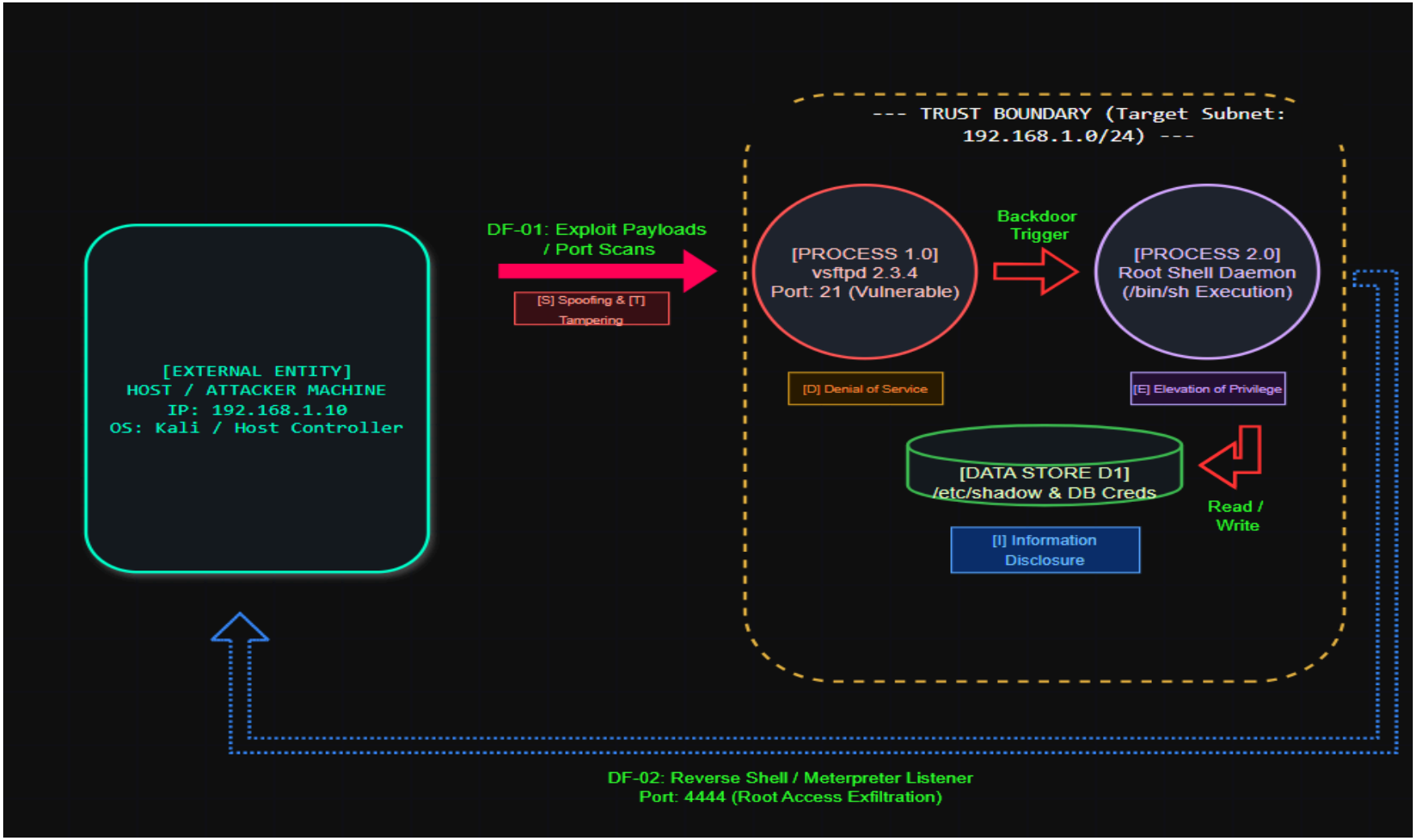
- The Host Machine (My main Windows/Linux PC)
- Home Wi-Fi Router (IP: 192.168.1.1)
- Any external websites or internet-facing servers

02. Asset Inventory

Asset_id	asset_name	owner	environment	ip_or_url	testing_allowed	excluded_actions	approved_window	evidence_classification
LAB-01	Local training web app	RabTech lab	Isolated localhost	http://127.0.0.1:8080	Yes	No denial of service or third-party scanning	Student-defined approved window	Confidential training evidence
LAB-02	Deliberately vulnerable VM	RabTech lab	Private host-only network	192.168.56.101	Yes	No persistence or outbound traffic	Student-defined approved window	Confidential training evidence

03. Data-Flow Diagram (DFD) & STRIDE Threat Model

3.1 Target Lab Data-Flow Diagram



3.2 STRIDE Threat Model Register

S.NO.	Threat Category	Target Element	Abuse Case / Attack Description	Mitigation
1	S - Spoofing	DF-01: Exploit Payloads	Attacker external network se apni IP ko spoof karke port scans aur malicious exploit payloads target network mein bhejta hai.	Network-level authentication aur strict firewall rules lagana jo bahar se aane wale suspicious packets ko block karein.
2	T - Tampering	DF-01: Exploit Payloads	Attacker data packets aur payload ko raste mein tamper/modify karke FTP server par bhejta hai taaki backdoor trigger ho sake.	Data transmission ke liye encryption (SSL/TLS) aur packet integrity checks ka istemaal karna.
3	R - Repudiation	Process 2.0 (Root Shell)	(Image me implicit) Root access milne ke baad attacker FTP ya system ke logs delete kar sakta hai taaki attack ka koi saboot na bache.	Audit logs ko kisi dusre secure, centralized server (SIEM) par real-time mein bhejna taaki attacker unhe delete na kar sake.
4	I - Information Disclosure	Data Store D1	Attacker system ke andar enter karke /etc/shadow file aur Database ke credentials ko read aur exfiltrate kar leta hai.	Sensitive files par strict permissions lagana aur database credentials ko strongly encrypt ya hash karke store karna.

5	**D - Denial of Service**	**Process 1.0 (vsftpd)**	**Attacker vulnerable vsftpd 2.3.4 service par excessive payloads bhej kar us service ko crash ya unresponsive kar sakta hai.**	**FTP service ko patch karna/update karna aur network par Rate Limiting / Intrusion Prevention System (IPS) lagana.**
6	**E - Elevation of Privilege**	**Process 2.0 (Root Shell)**	**vsftpd ke backdoor ko trigger karke attacker ko seedha root level ka /bin/sh shell (highest authority) mil jaata hai**	**Vulnerable software versions ko system se turant hatana aur Principle of Least Privilege (PoLP) strictly lagu karna.**

04._Rules_of_Engagement

Rules of Engagement (RoE)

1. Test Windows: Testing will be conducted Wednesday,3:00 P.M. to 4:00 P.M. IST.

2. Evidence Handling: All screenshots, logs, and vulnerability data will be stored locally in an encrypted folder and securely deleted after the internship task is approved.

3. Escalation Path: In case of any critical system failure or accidental out-of-scope scan, testing will stop immediately and the Internship Mentor will be notified.

4. Stop Conditions (When to halt testing):

- If the target Virtual Machine crashes or becomes unresponsive (DoS).
- If real malware or an active third-party intrusion is detected in the lab.
- If testing accidentally affects the Host PC's internet connection.